Thursday, 5 March 2026

Adobe_CCF

Subject - Study about the CCF for the Adobe and trying to make the automation process for the Adobe_CCF mapping

This file contains all the resources what I get from the different platforms.

The Adobe Common Control Framework (CCF)

We believe that a sound compliance and risk management strategy is as important to the success of an organization as the company's product strategy. Adobe demonstrates our commitment to security by implementing a range of important industry standards and complying with government regulations concerning the security and privacy of data. As new security standards and regulatory requirements are developed and adopted by the industry, Adobe reviews them and adopts those with relevance to our customers.

To support our ongoing compliance efforts, Adobe implemented an open-source framework of security processes and controls called the Common Controls Framework (CCF). CCF helps protect Adobe infrastructure, applications and services, as well as helps us comply with a number of industry-accepted best practices, standards, regulations and certifications. In creating the CCF, Adobe analyzed the criteria for the most common security certifications for cloud-based businesses and rationalized the more than 4,300 requirements down to Adobe-specific controls that map to 21 industry standards.

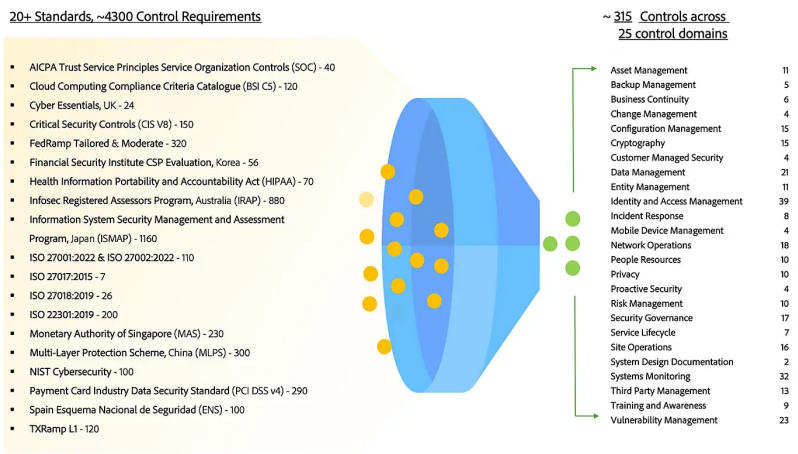

Diagram Visuals and Text

This funnel diagram shows the security standards and control requirements Adobe has rationalized to create common controls across various control domains.

The left side of the diagram is titled 20+ Standards, approximately 4300 Control Requirements (CRs). Under the title is the following list of standards, each with by a number representing control requirements:

- AICPA Trust Service Principles Service Organization Controls (SOC) – 40
- Cloud Computing Compliance Criteria Catalogue (BSI C5) – 120
- Cyber Essentials, UK -24
- Critical Security Controls (CIS V8) – 150
- FedRAMP Tailored & Moderate – 320
- Financial Security Institute CSP Evaluation, Korea - 56
- Health Insurance Portability and Accountability Act (HIPAA) – 70
- InfoSec Registered Assessors Program, Australia (IRAP) – 880
- Information System Security Management and Assessment Program, Japan (ISMAP) - 1160
- ISO 27001:2022 & 27002:2022 – 110
- ISO 27017:2015 – 7
- ISO 27018:2019 – 26
- ISO 22301:2019 – 200
- Monetary Authority of Singapore (MAS) – 230
- Multi-Layer Protection Scheme, China (MLPS) – 300
- NIST Cybersecurity - 100
- Payment Card Industry Data Security Standard (PCI DSS v4) – 290
- Spain Esquema Nacional de Seguridad (ENS) – 100
- TXRAMP L1 - 120

The center of the diagram shows a funnel labelled CCF Rationalization. The standards and controls listed on the left side of the graphic are represented by few yellow dots moving into the funnel. Few green dots are emerging from the funnel on the right side of the graphic. They represent the resulting common controls.

The right side of the diagram is titled Approximately 315 common controls across 25 control domains. Under the title is the following list of control domains, each with a number representing common controls:

- Asset Management – 11 Controls
- Backup Management – 5 Controls
- Business Continuity – 6 Controls
- Change Management – 4 Controls
- Configuration Management – 15 Controls
- Cryptography – 15 Controls
- Customer Managed Security – 4 Controls
- Data Management – 21 Controls
- Entity Management – 11 Controls
- Identity and Access Management – 39 Controls
- Incident Response – 8 Controls
- Mobile Device Management – 4 Controls
- Network Operations – 18 Controls
- People Resources – 10 Controls
- Privacy – 10 Controls
- Proactive Security – 4 Controls
- Risk Management – 8 Controls
- Security Governance – 17 Controls
- Service Lifecycle – 7 Controls
- Site Operations – 16 Controls
- System Design Documentation – 2 Controls

- Systems Monitoring- 32 Controls
- Third Party Management – 13 Controls
- Training and Awareness – 9 Controls
- Vulnerability Management – 23 Controls

There (Adobe) Ongoing Efforts

Compliance is a continuous process that includes periodic internal audits, external assessments and continuous controls monitoring. Adobe is subjected to regular third-party audits and periodic reviews to ensure we consistently meet commitments. Adobe has also invested in developing an enterprise-wide governance, risk, and compliance (GRC) automation platform to help maintain an effective governance model for the compliance program.

Open-source and Ready to Use

The Common Controls Framework (CCF) has been open sourced (now at version 5.0) to help the broader security and risk management community achieve their own compliance goals. We regularly update the framework as regulations evolve or new industry standards are integrated into our compliance regime. We invite you to use this framework to help accelerate and standardize your own ongoing compliance efforts. Download CCF today and we always welcome feedback on its development.

I HAVE PASTED THE CCF PDF AND XLS FILE IN THE SOURCE ALREADY

What I have understood:

Companies must follow many rules and standards to protect data.

Example:-

GDPR - Protect Personal data
HIPPA - Protect health data
ISO - Security best Practices
SOC2 - Security for service companies

Each of these has hundreds of rules

Like - User strong password, user encrypted data etc.

The Problem :-
If a Company follows 4 framework they may have to implement the same rule 4 times
That becomes expensive and messy.
The same rule may appears in many frameworks.

Different compliance framework often ask for the same security requirements but they describe them differently

Ex:-
ISO, SOC2, GDPR, HIPAA
each ask for the password security but in different way

ISO - User must have secure authentication mechanism
SOC2 - Logical access to system must be restricted and authenticated
GDPR - Organisations must ensure appropriate technical security measures

They sound different but all means same, without common control framework companies has:

4 documents
4 compliance mapping
4 audits
4 monitoring processes

The idea behind CCF:

A common Control Framework solve this problem, instead of doing the same work multiple times, the company creates once set of security controls that satisfy all the framework at once. Like a checklist.

Instead of writing 4 rules the company writes 1 rule.

Example:-

- Math exam
- Physics exam
- Engineering exam
  - each have Algebra

Instead of Learning that 3 times learn only one time

What I wanted to build.

An common controls framework mapper.

The CCF Mapper enables organisations to upload their internal controls and incorporate new external control requirements. The system intelligently maps framework requirements to the company's internal controls and produces an updated control mapping file.

Framework Requirements → Company Internal Controls

Adobe-CCF PDF Table Structure:

Common Controls Framework (CCF) Mapping Table – Column & Row Explanation

Overview

The Common Controls Framework (CCF) mapping table is used to map **internal organizational security controls** to **multiple external compliance frameworks**.

Each **row** in the table represents a **single internal control**, while each **column** represents either:

- Metadata describing the internal control
- A compliance framework
- A reference mapping to a specific control within that framework

This structure enables organizations to implement **one internal control that satisfies requirements across multiple compliance standards**.

Table Structure

The table can be divided into three main sections:

1. Internal Control Information
2. Framework Applicability Indicators
3. Framework Reference Mapping

1. Internal Control Information Columns

These columns define the internal control used in the organization's CCF.

CCF ID

A unique identifier assigned to each internal control in the CCF library.

Example:

AM-01
BC-01
BM-01

Control ID prefixes typically represent the control domain:

Prefix	Domain
AM	Asset Management
BC	Business Continuity
BM	Backup Management

Example interpretation:

AM-01 → Asset Management Control #1
BC-04 → Business Continuity Control #4

This identifier allows the control to be referenced consistently across compliance mappings.

Control Domain

The domain categorizes the control according to the security area it belongs to.

Examples:

Asset Management
Business Continuity
Backup Management

Domains help organize controls into logical security categories.

Example domain purposes:

Domain	Description
Asset Management	Tracking and managing IT assets
Business Continuity	Disaster recovery and operational resilience
Backup Management	Data backup and recovery processes

Control Name

A short descriptive title summarizing the purpose of the control.

Examples:

Inventory Management
Business Continuity Plan
Backup Configuration

The control name should provide a quick understanding of the control's objective.

Control Description

A detailed explanation of the control and what the organization must implement to satisfy it.

Example:

"Organization maintains an inventory of information systems which is reconciled on a periodic basis."

This describes the operational requirement that must be implemented within the organization.

Typical description components include:

- The required process
- Responsible entities
- Operational frequency
- Scope of the control

2. Framework Applicability Columns

These columns represent various **external compliance frameworks**.

Examples of frameworks included in the table:

- NIST Cybersecurity Framework
- CIS Critical Security Controls v8
- ISO 27001
- ISO 27002
- ISO 27017
- ISO 27018

- HIPAA Security Rule
- PCI DSS 4.0
- SOC 2
- BSI C5
- Cyber Essentials UK
- ENS
- FedRAMP
- TX-RAMP
- IRAP
- ISMAP
- MAS
- MLPS
- KFSI

Each column indicates whether the internal control applies to the respective framework.

Applicability Indicator (X)

An "**X**" in a framework column indicates that the internal control satisfies a requirement within that framework.

Example:

Control	ISO 27001	NIST	SOC 2
AM-01	X	X	X

Meaning:

The AM-01 control is relevant to and supports compliance with ISO 27001, NIST, and SOC 2.

3. Framework Reference Mapping Columns

These columns specify the **exact control identifiers within each framework** that correspond to the internal control.

Examples:

Framework	Reference
NIST CSF	ID.AM-2
NIST 800-53	CM-08
ISO 27001	8.1.1.1
SOC 2	CC6.1

These references allow auditors and compliance teams to verify that the internal control addresses specific framework requirements.

Example Row Breakdown

Example control entry:

CCF ID: AM-01
Control Domain: Asset Management
Control Name: Inventory Management

Control Description:

Organization maintains an inventory of information systems which is reconciled periodically.

Framework mappings:

Framework	Control Reference
NIST CSF	ID.AM-2
CIS Controls	1.1
ISO 27001	8.1.1.1
SOC 2	CC6.1

Interpretation:

The AM-01 internal control ensures that all organizational assets are inventoried and tracked. This control simultaneously satisfies requirements from multiple compliance frameworks.

Purpose of the CCF Mapping Table

The primary objective of this table is to enable **control normalization across compliance frameworks**.

Instead of implementing separate controls for each framework, organizations can:

1. Define one internal control
2. Map it to multiple external compliance requirements
3. Use a single implementation to demonstrate compliance

Benefits of the CCF Mapping Model

Reduced duplication of controls
Simplified audit preparation
Centralized compliance management
Improved traceability between internal controls and regulatory requirements
Scalable compliance across multiple frameworks

Conceptual Model

Internal Control
↓
Mapped to
↓
Multiple Compliance Framework Controls

Example:

Backup Control
→ ISO 27001
→ SOC 2
→ HIPAA
→ NIST
→ PCI DSS

Summary

The CCF mapping table is a centralized structure that allows organizations to manage security controls efficiently by linking internal controls with multiple external compliance frameworks.

Each row represents a single internal control, while the columns provide metadata and mapping relationships that demonstrate how that control satisfies requirements across different regulatory and security standards.